

Responsible AI Redesign of a Fraud Detection System

Machine Learning Lifecycle Analysis and Governance Proposal

Prepared by: Millen Wondimu and Group Members

Group Assignment

August 15, 2026

1. Problem Definition and Stakeholder Analysis

Objective and Decision Context

The system's objective is to detect unauthorized payment-card transactions quickly enough to prevent or limit loss while allowing legitimate transactions to proceed with minimal interruption. It operates at authorization time, analyzes transaction and account behavior, and produces a fraud probability or risk score. The score does not have to be the final decision. It can feed a policy engine that chooses among approval, additional authentication, a temporary hold, or referral to a fraud analyst.

The target variable is a binary label: fraudulent transaction (1) or legitimate transaction (0). Labels may come from confirmed customer disputes, chargeback investigations, merchant reports, and analyst decisions. Because investigations and chargebacks can take days or weeks, the system must distinguish provisional labels from mature labels. The unit of prediction is one attempted transaction, but the consequences extend to the customer, merchant, issuer, and payment network.

Stakeholders and Their Needs

Stakeholder	Primary interest	Potential harm
Cardholders	Protection, fast approvals, clear notifications, appeal	Fraud loss, embarrassment, missed essential purchase, account lockout
Merchants	Legitimate sales and manageable chargebacks	Lost sales, delayed fulfillment, reputational damage
Bank/issuer	Lower fraud loss and regulatory compliance	Financial loss, enforcement, customer attrition
Fraud analysts	Prioritized, explainable alerts	Alert fatigue, inconsistent decisions, excessive workload
Data/ML teams	Reliable data, measurable performance, safe updates	Hidden leakage, drift, brittle deployment
Privacy, security, audit, and regulators	Lawful use, controls, traceability, accountability	Data misuse, breaches, discrimination, weak evidence

Success Criteria and Constraints

Overall accuracy is not a sufficient success measure because fraud is rare. A model that predicts every transaction as legitimate may appear highly accurate while detecting no fraud. The primary technical measures should include precision, recall, precision-recall area under the curve (PR-AUC), F1-score, false-positive rate, calibration, and recall at the fraud-review team's daily capacity. Operational measures should include dollars prevented, false-decline rate, review time, verification completion, customer complaints, and appeal reversals. Metrics must also be reported by meaningful customer and transaction subgroups.

- Safety target: detect a high share of confirmed fraud, especially high-dollar and repeat fraud.
- Customer target: keep false declines and unnecessary verification below approved limits.
- Operational target: keep alert volume within analyst capacity and meet real-time latency requirements.
- Responsible-AI target: document data lineage, model limitations, subgroup results, approvals, incidents, and appeals.

2. Data Audit and Preprocessing Evaluation

Data Sources and Label Quality

Potential data sources include transaction amount, time, merchant category, channel, device and browser signals, country or region, card-present status, recent transaction velocity, account tenure, prior disputes, authentication results, and historical customer spending patterns. External signals may include compromised-card lists, merchant-risk indicators, and network alerts. Directly identifying card data should be tokenized or excluded from the modeling environment whenever possible. PCI DSS provides baseline technical and operational requirements for protecting payment account data (PCI Security Standards Council, n.d.).

The most important audit question is whether the label represents confirmed fraud. A chargeback is not always fraud, an analyst can make an error, and some fraud is never reported. Recent transactions may have incomplete outcomes because of delayed investigations. Training on immature labels would make recent legitimate transactions appear negative and may hide newer fraud tactics. The dataset should therefore record label source, confirmation date, confidence level, and any reversal.

Preprocessing Plan

- Remove duplicate events and reconcile reversals, retries, refunds, and authorization updates.
- Validate ranges, units, timestamps, currencies, merchant categories, and geographic codes.
- Handle missing values by separating unknown from not applicable; add missingness indicators when absence may carry information.
- Create only features available at decision time, such as transaction velocity over the previous hour, to prevent target leakage.
- Encode categorical variables consistently; cap or transform extreme amounts only when the change preserves meaningful high-risk behavior.
- Fit imputers, encoders, resampling, and scaling on training data only, then apply the learned transformations to validation and test data.
- Use class weights or carefully controlled resampling on training folds only. Keep validation and test sets at the natural fraud rate.

Bias Entry Points

Bias can enter through historical policing of fraud, unequal reporting, merchant coverage, device availability, geography, and analyst decisions. For example, customers who travel frequently, use shared

devices, live near borders, shop at small merchants, or lack consistent digital histories may appear unusual even when their transactions are legitimate. Geographic location, language, device type, and merchant category can also act as proxies for protected or economically sensitive characteristics. These factors should not automatically be removed, because some may be necessary for fraud prevention, but their necessity and impact must be tested and documented.

Data risk	Example	Control
Label bias	Disputes and analyst decisions contain mistakes	Mature-label window, confidence field, reversal process
Representation gap	New or low-activity accounts have little history	Coverage analysis, fallback rules, subgroup evaluation
Leakage	Chargeback result appears in a training feature	Point-in-time feature review and automated leakage checks
Proxy effect	Location or device correlates with protected status	Necessity review, fairness testing, constrained use
Security risk	Raw card data enters analytics workspace	Tokenization, least privilege, encryption, retention limits

3. Model Selection and Validation Strategy

Candidate Model Families

Logistic regression should serve as the baseline because it is fast, auditable, and relatively easy to explain. A decision tree or rule-based system is also useful for transparent policy rules. Random forests and gradient-boosted trees can learn nonlinear relationships and feature interactions common in transaction data and are strong candidates for the main model. Deep neural networks and anomaly-detection methods may add value when data volume is very large or labeled fraud is scarce, but they increase complexity, calibration, and explanation challenges. The recommended first production design is a gradient-boosted tree model compared against logistic regression and existing rules.

Model family	Strength	Limitation	Role
Logistic regression	Fast, stable, interpretable	May miss nonlinear interactions	Required baseline/challenger
Decision tree/rules	Easy to explain and govern	Can be brittle or overfit	Policy layer and fallback
Random forest	Robust nonlinear ensemble	Less transparent; larger	Candidate challenger
Gradient boosting	Strong tabular performance	Tuning and explanation needed	Recommended main candidate
Neural network	Can learn complex patterns	Data hungry and harder to govern	Later-stage experiment
Anomaly detection	Finds unusual, unlabeled	Unusual does not equal fraud	Supplementary signal

	behavior		
--	----------	--	--

Validation Design

A random split would allow future patterns to leak backward and would not represent production. Instead, transactions should be ordered by time. An example design is 70% oldest data for training, the next 15% for validation and threshold selection, and the most recent 15% as a locked test set. Rolling or expanding-window cross-validation within the training period should measure stability across multiple time windows. All transactions from the same account or linked fraud episode should remain in one fold when practical to prevent near-duplicate behavior from appearing on both sides of a split.

Model selection should prioritize PR-AUC because it focuses on performance for the rare positive class. Precision, recall, F1-score, recall at a fixed alert volume, and expected financial cost should be reported at the selected threshold. ROC-AUC may be included but can look favorable under severe class imbalance. Probability calibration should be assessed with calibration plots and Brier score because thresholds and risk tiers depend on meaningful scores. Bootstrap confidence intervals can show whether apparent improvements are stable.

Thresholds should be chosen through a cost-sensitive policy that considers fraud amount, false-decline harm, verification cost, analyst capacity, and organizational risk tolerance. Before launch, the model should run in shadow mode against live traffic. Analysts can compare its recommendations with the current system without allowing it to affect customers. Production rollout should begin with a small traffic share and include rollback criteria.

4. Ethical, Fairness, and Privacy Assessment

Fairness and Subgroup Impacts

Fraud detection is protective, but its errors are not evenly experienced. A false negative may leave a customer exposed to unauthorized charges, while a false positive may block groceries, medication, travel, or emergency purchases. Repeated verification can also make some customers feel unfairly suspected. Fairness analysis should therefore evaluate both fraud recall and legitimate-transaction approval rates rather than forcing a single parity measure that could reduce security.

Where legally and operationally permitted, the team should measure false-positive rate, false-negative rate, precision, recall, calibration, and appeal reversals across age bands, geography, account tenure, language, disability-related accessibility needs, card-present versus online channels, domestic versus international purchases, and other relevant groups. Protected attributes should be tightly controlled and used for auditing rather than routine scoring unless there is a lawful, documented reason. Small-group results require uncertainty intervals and minimum sample rules so the team does not overreact to noise.

- Investigate material subgroup gaps and trace them to labels, features, thresholds, or operational processes.
- Test whether removing or constraining proxy features meaningfully reduces harm without creating unacceptable fraud loss.

- Offer accessible verification choices and a fast appeal path; do not require one device or communication channel.
- Measure intersectional groups when sample size allows because combined characteristics can reveal hidden harms.

Privacy, Security, and Governance

Transaction histories can reveal location, health-related purchases, religious activity, relationships, and personal routines. The organization should collect only features necessary for fraud prevention, document the purpose of each feature, restrict secondary use, and define retention and deletion schedules. Tokenization, encryption, role-based access, logging, secure development, vendor controls, and incident response are essential. The NIST Privacy Framework recommends managing privacy risk across the data lifecycle and considering problems individuals may experience because of data processing (NIST, 2025).

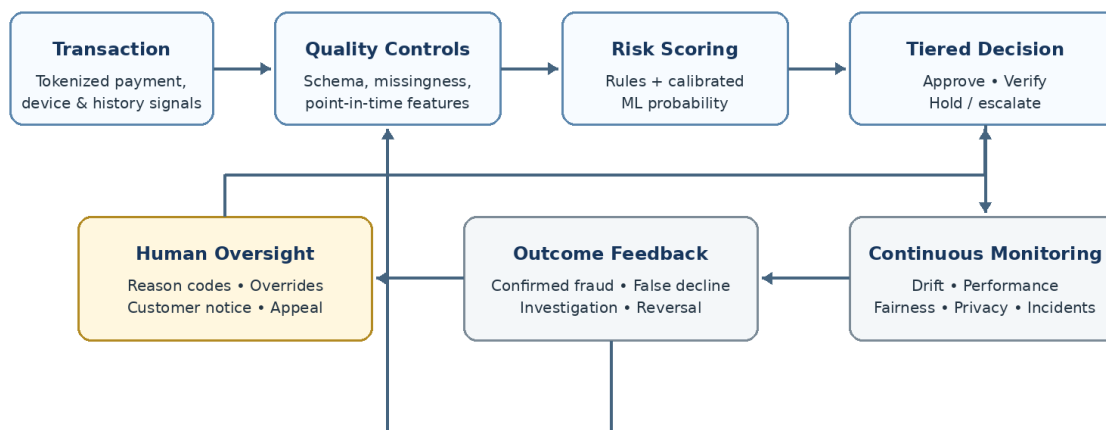
Governance should assign an accountable executive owner and a cross-functional model-risk committee. The committee should include fraud operations, ML, privacy, security, legal/compliance, customer experience, and internal audit. Required artifacts include a model card, data sheet, data lineage, approval record, validation report, fairness assessment, change log, incident log, and retirement plan. Material model or threshold changes should require independent review, version control, and rollback readiness. NIST's AI RMF organizes responsible risk work around Govern, Map, Measure, and Manage and emphasizes that trustworthiness depends on context (Tabassi, 2023).

5. Monitoring and Post-Deployment Plan

Monitoring Workflow

Monitoring must connect technical signals to customer and business outcomes. Data-quality checks should run continuously or daily, model and operational dashboards should be reviewed daily, subgroup and calibration reports should be reviewed weekly or monthly depending on volume, and a formal governance review should occur at least quarterly. Confirmed fraud labels arrive late, so leading indicators such as score distribution, feature missingness, alert rate, and verification failure should be monitored before mature outcome metrics become available.

Responsible Fraud Detection Workflow



Governance surrounds every stage: owners, documentation, access controls, thresholds, review, and rollback.

Figure 1. Responsible fraud detection workflow with feedback and human oversight.

Monitor	Example trigger	Response
Data quality	Missingness, schema, or category shift exceeds limit	Quarantine batch, use fallback, investigate pipeline
Population drift	PSI/KS or score-distribution alert	Segment analysis; increase review; assess retraining
Performance	Recall, precision, calibration, or cost breaches limit	Threshold review, root-cause analysis, rollback/challenger
Fairness	Material subgroup error gap or complaint pattern	Impact review, feature/threshold change, remediation
Operations	Alert backlog, latency, or verification abandonment	Adjust routing and staffing; activate safe fallback
Security/privacy	Unauthorized access, extraction attempt, incident	Contain, notify response teams, preserve evidence

Human Oversight and Incident Response

Human review should be meaningful rather than ceremonial. Analysts need reason codes, recent relevant history, uncertainty, and clear procedures. They should be able to override a recommendation with a documented reason, and override patterns should feed model evaluation. Customers need prompt notifications, plain-language explanations, more than one verification method, and a clear appeal route. High-impact declines, vulnerable-customer cases, and repeated flags should receive enhanced review.

An incident playbook should define severity, ownership, containment, customer communication, rollback, and post-incident review. A severe incident includes a sudden increase in false declines, missed coordinated fraud, material subgroup harm, data leakage, or scoring outages. The system should fail safely: if critical features are unavailable, it should use conservative rules and step-up verification instead of silently treating missing data as low risk.

6. System Redesign Proposal

Redesigned Architecture and Decision Policy

The redesigned system separates prediction from action. A governed feature pipeline produces point-in-time features using tokenized data. A gradient-boosted model generates a calibrated risk score, while transparent rules identify known threats and enforce policy constraints. The decision layer combines score, transaction value, customer context, confidence, and analyst capacity. This design makes it possible to change operational thresholds without retraining the model and prevents a single score from automatically determining every customer outcome.

- Low risk: approve and continue passive monitoring.
- Medium risk: request step-up verification through accessible customer-selected channels.
- High risk: temporarily hold or decline, notify the customer, and prioritize human review.
- Uncertain or out-of-distribution: route to review or safe fallback rules instead of making an overconfident automated decision.

Implementation Roadmap

Phase	Main work	Exit requirement
1. Govern and audit	Define owners, risk tolerance, data inventory, stakeholder harms	Approved use case, documentation, and metrics
2. Build and validate	Create point-in-time data, baseline and boosted models, temporal tests	Independent validation and subgroup review pass
3. Shadow deployment	Score live traffic without customer impact	Stable latency, data, calibration, and alert volume
4. Controlled rollout	Small traffic share, human review, customer feedback	No critical harm; rollback tested
5. Continuous operation	Monitor drift, outcomes, fairness, incidents, appeals	Quarterly governance approval and documented changes

Expected Benefits and Residual Risks

The redesign should detect more costly fraud, reduce unnecessary declines, prioritize analyst work, and create stronger evidence for audits and model changes. Calibration and tiered actions make the system more proportional: uncertainty leads to verification or review rather than an automatic accusation.

Time-based validation and drift monitoring address the reality that fraud patterns and customer behavior change. Privacy controls reduce exposure of payment and behavioral data, while subgroup analysis and appeals reveal harms that average metrics can hide.

Residual risk remains. Fraudsters may adapt to the model, labels will remain delayed and imperfect, and some fairness measurements may be limited by lawful data availability or small samples. Human reviewers can also introduce inconsistency. These risks cannot be eliminated by a model alone. They require layered security, training, quality assurance, customer support, red-team exercises, periodic independent review, and authority to pause or retire the system.

Conclusion

A responsible fraud detection system is not simply the classifier with the highest test score. It is a controlled socio-technical process that combines reliable data, appropriate validation, proportional decisions, privacy protection, fairness testing, human oversight, customer remedies, and continuous monitoring. The proposed redesign treats fraud prevention and customer protection as connected goals. Its most important principle is that every model error affects a person or organization, so performance must be measured in the context of real consequences and governed throughout the full machine learning lifecycle.

Group Presentation Script (2–4 Minutes)

Speaker 1 — System and objective: Our group selected a real-time payment-card fraud detection system. The model reviews each transaction and predicts whether it is fraudulent. This can reduce unauthorized losses, but the system must also avoid blocking legitimate customers. We therefore defined success using recall, precision, false-positive rate, financial impact, customer complaints, and review capacity instead of accuracy alone.

Speaker 2 — Key risks: We identified several major risks. Fraud is rare, so the data are highly imbalanced. Labels can be delayed or incorrect because chargebacks and investigations take time. Historical data may underrepresent new customers or unusual but legitimate behavior. Sensitive transaction histories create privacy and security concerns. False declines may also affect some customer groups more than others.

Speaker 3 — Proposed improvements: Our redesign uses time-based validation, a logistic-regression baseline, and a calibrated gradient-boosted model. It separates the model's risk score from the final action. Low-risk transactions are approved, medium-risk transactions receive additional verification, and high-risk or uncertain cases receive human review. We also added subgroup testing, data minimization, tokenization, drift monitoring, appeal options, and documented governance.

Speaker 4 — Practitioner insight: The most important insight is that responsible machine learning does not end when the model is deployed. Fraud patterns, customer behavior, and data quality will change. Every practitioner should monitor both model performance and human impact, provide a way to challenge errors, and be prepared to adjust or stop the system when harm exceeds its benefits.

Group Reflection

This project helped our group understand that fraud detection is more than a technical classification problem. At first, it was easy to focus on catching the greatest number of fraudulent transactions. As we examined the entire lifecycle, we realized that false declines, delayed labels, customer privacy, analyst workload, and unequal subgroup impacts are also part of system performance. Discussing the issue from the perspectives of customers, merchants, analysts, developers, and regulators helped us see why one metric cannot represent success.

Our main lesson is that responsible AI requires continuous responsibility. A strong validation result is important, but it does not guarantee that the system will remain reliable after deployment. Human review, monitoring, appeals, documentation, and clear ownership are necessary because both fraud tactics and normal customer behavior change. The redesign showed us that an effective model should protect the organization while still respecting the people affected by its decisions.

References

Breskuvienė, D., & Dzemyda, G. (2024). Enhancing credit card fraud detection: Highly imbalanced data case. *Journal of Big Data*, 11. <https://doi.org/10.1186/s40537-024-01059-5>

National Institute of Standards and Technology. (2025). Privacy Framework.
<https://www.nist.gov/privacy-framework>

PCI Security Standards Council. (n.d.). PCI Data Security Standard (PCI DSS).
<https://www.pcisecuritystandards.org/standards/pci-dss/>

Tabassi, E. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0) (NIST AI 100-1).
National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.AI.100-1>

Yeşilkanat, A. (2020). An adaptive approach on credit card fraud detection using transaction aggregation and word embeddings. *Journal of Information Security and Applications*, 55, 102600.
<https://doi.org/10.1016/j.jisa.2020.102600>